

Marco integrativo GQM + PRAGMATIC para indicadores ISO/IEC 27001

1. Introducción

Este marco integra el enfoque Goal-Question-Metric (GQM) con los criterios PRAGMATIC para diseñar, evaluar y gobernar indicadores de ciberseguridad alineados con ISO/IEC 27001:2022 y con objetivos nacionales y regulatorios (NIS2, estrategias de ciberseguridad, etc.). [web:40][web:43][web:51][web:46][web:52]

GQM garantiza la trazabilidad descendente desde objetivos de alto nivel hasta datos técnicos, mientras que PRAGMATIC ofrece un conjunto de criterios para juzgar la “calidad” de cada métrica: Predictive, Relevant, Actionable, Genuine, Meaningful, Accurate, Timely, Independent, Cheap. [web:44][web:49][web:52]

2. Resumen del enfoque GQM

GQM propone una estructura jerárquica:

- Goal (Objetivo): qué se quiere lograr y por qué, en un contexto concreto.
- Question (Pregunta): qué hay que preguntar para saber si avanzamos hacia el objetivo.
- Metric (Métrica): qué medimos, con qué fórmula y con qué datos, para responder a la pregunta. [web:40][web:43][web:51]

En nuestro contexto, los objetivos pueden alinearse con:

- Objetivos nacionales / NIS2 / estrategias de ciberseguridad.
- Objetivos de la organización y del SGSI (confidencialidad, integridad, disponibilidad, resiliencia).
- Objetivos operativos (reducción de incidentes, tiempos de respuesta, exposición, etc.). [web:43][web:50]

3. Resumen del marco PRAGMATIC

El acrónimo PRAGMATIC se utiliza como “metamétrica” para valorar la utilidad de cada métrica: [web:44][web:49][web:52]

- P – Predictive (Predictivo): ayuda a anticipar resultados futuros, no solo a describir el pasado.
- R – Relevant (Relevante): está claramente relacionado con objetivos de negocio y de seguridad.
- A – Actionable (Accionable): su cambio sugiere o impulsa acciones concretas de gestión.
- G – Genuine (Genuino): refleja la realidad, sin manipulación fácil ni efectos cosméticos.
- M – Meaningful (Significativo): es comprensible para la audiencia objetivo y aporta interpretación.
- A – Accurate (Preciso): los datos son suficientemente correctos para apoyar decisiones.
- T – Timely (Oportuno): se calcula y presenta con la frecuencia adecuada.
- I – Independent (Independiente): no está excesivamente contaminado por intereses de quien lo reporta.
- C – Cheap (Rentable): el coste de obtenerlo y mantenerlo es razonable.

Cada métrica se puntúa de 1 a 5 en cada dimensión, generando un “perfil PRAGMATIC” que permite priorizar y depurar el catálogo de indicadores.

4. Taxonomía de objetivos e indicadores ISO 27001 (punto de partida)

Partimos de las familias de indicadores ya definidas en el informe original:

1. Madurez y desempeño global del SGSI.
2. Gestión de riesgos (KRIs).
3. Controles técnicos, vulnerabilidades y exposición.
4. Incidentes, SOC y respuesta.
5. Concienciación, formación y comportamiento del usuario.
6. Continuidad de negocio y resiliencia.
7. Proveedores, terceros y cadena de suministro.
8. Entorno regulatorio y cumplimiento (NIS2, GDPR).
9. Automatización, calidad de datos y gobierno de métricas.

Cada familia se convierte en un conjunto de objetivos GQM, que se refinan en preguntas y métricas concretas.

5. Ejemplo de cadena GQM desde objetivos nacionales

Tomamos un objetivo nacional simplificado inspirado en estrategias y datos de INCIBE/ENISA:

- Goal G-NAT-1 (nivel nacional)
“Reducir en un 30 % la frecuencia y el impacto de incidentes de ciberseguridad significativos en el territorio en cinco años, especialmente en operadores esenciales y administraciones públicas.”
[web:16][web:12]

Este objetivo se traduce a nivel organizativo y después a métricas:

- **Goal G-ORG-1 (nivel organizativo)**
“Reducir la probabilidad y el impacto de incidentes significativos en la organización, alineando la capacidad de detección, respuesta y resiliencia con los estándares ISO 27001 y los requisitos NIS2.”
- **Questions (ejemplos)**
Q-ORG-1.1: ¿Estamos detectando incidentes con suficiente rapidez antes de que generen un impacto grave?
Q-ORG-1.2: ¿Resolvemos los incidentes en los plazos acordados y con efectividad?
Q-ORG-1.3: ¿Se reduce la severidad media de los incidentes a lo largo del tiempo?
- **Metrics (ejemplos)**
M-INC-MTTD: Tiempo medio de detección de incidentes (en horas).
M-INC-MTTR: Tiempo medio de respuesta/resolución de incidentes (en horas).
M-INC-SLA: % de incidentes resueltos dentro del SLA.
M-INC-SEV: Severidad media ponderada de incidentes por periodo.

Goal G-ORG-1 (nivel organizativo)

“Reducir la probabilidad y el impacto de incidentes significativos en la organización, alineando la capacidad de detección, respuesta y resiliencia con los estándares ISO 27001 y los requisitos NIS2.”

Questions (ejemplos)

- Q-ORG-1.1: ¿Estamos detectando incidentes con suficiente rapidez antes de que generen un impacto grave?
- Q-ORG-1.2: ¿Resolvemos los incidentes en los plazos acordados y con efectividad?
- Q-ORG-1.3: ¿Se reduce la severidad media de los incidentes a lo largo del tiempo?

Metrics (ejemplos)

- M-INC-MTTD: Tiempo medio de detección de incidentes (en horas).
- M-INC-MTTR: Tiempo medio de respuesta/resolución de incidentes (en horas).
- M-INC-SLA: % de incidentes resueltos dentro del SLA.
- M-INC-SEV: Severidad media ponderada de incidentes por periodo.

Cada métrica se calificará luego con PRAGMATIC y se vinculará al bloque correspondiente de la encuesta.

6. Catálogo resumido de objetivos GQM por familia de indicadores

6.1 Madurez y desempeño global (G-MAD-*)

- Goal G-MAD-1: “Asegurar que el SGSI alcanza un nivel de madurez coherente con el perfil de riesgo de la organización y las expectativas regulatorias.”
- Preguntas típicas:
 - Q-MAD-1.1: ¿Cuál es el nivel actual de madurez del SGSI frente al conjunto de controles?
 - Q-MAD-1.2: ¿Tiende a mejorar, estancarse o empeorar?
- Métricas ilustrativas:
 - M-MAD-SCORE: Puntuación global de madurez (0–100).
 - M-MAD-DELTA: Variación anual del nivel de madurez.

6.2 Riesgos (G-RISK-*)

- Goal G-RISK-1: “Mantener los riesgos de seguridad de la información dentro del apetito de riesgo aprobado.”
- Preguntas:
 - Q-RISK-1.1: ¿Qué porcentaje de activos críticos tiene análisis de riesgo actualizado?
 - Q-RISK-1.2: ¿Qué porcentaje de riesgos se trata en el plazo previsto?
 - Q-RISK-1.3: ¿Qué proporción de riesgos residuales supera el apetito de riesgo?
- Métricas:
 - M-RISK-ASSETS: % activos críticos con análisis vigente.
 - M-RISK-TREATED: % riesgos tratados en plazo.
 - M-RISK-OVERAPP: % riesgos residuales sobre apetito.

6.3 Controles técnicos, vulnerabilidades, exposición (G-TECH-*)

- Goal G-TECH-1: “Reducir significativamente la superficie de ataque explotable mediante una gestión eficaz de vulnerabilidades y configuración segura.”
- Preguntas:
 - Q-TECH-1.1: ¿En cuánto tiempo se corrigen vulnerabilidades críticas?
 - Q-TECH-1.2: ¿Qué porcentaje de sistemas mantiene versiones soportadas?
 - Q-TECH-1.3: ¿Qué proporción de activos expuestos a internet presenta vulnerabilidades críticas abiertas?
- Métricas:
 - M-TECH-CRIT-MTTR: Tiempo medio de corrección de vulnerabilidades críticas.
 - M-TECH-SUPPORTED: % sistemas en versiones soportadas.
 - M-TECH-EXPOSED: % activos expuestos con vulnerabilidades críticas.

6.4 Incidentes, SOC, respuesta (G-INC-*)

- Goal G-INC-1 ya ilustrado arriba.
- Métricas clave: M-INC-MTTD, M-INC-MTTR, M-INC-SLA, M-INC-SEV, M-INC-RECUR (tasa de reincidencia).

6.5 Concienciación y comportamiento (G-AWARE-*)

- Goal G-AWARE-1: “Minimizar la probabilidad de incidentes causados por error humano a través de formación y concienciación efectivas.”
- Preguntas:
 - Q-AWARE-1.1: ¿Qué porcentaje de empleados completa la formación obligatoria?
 - Q-AWARE-1.2: ¿Cuál es la tasa de clic en pruebas de phishing?
 - Q-AWARE-1.3: ¿Aumenta el número de reportes legítimos de phishing?
- Métricas:
 - M-AWARE-COVER: % empleados con formación completada.
 - M-AWARE-PHISH-CLICK: % clic en simulaciones.
 - M-AWARE-PHISH-REPORT: N° reportes legítimos/100 empleados.

6.6 Continuidad y resiliencia (G-RES-*)

- Goal G-RES-1: “Garantizar que los procesos críticos pueden recuperarse dentro de los RTO/RPO definidos.”
- Métricas:
 - M-RES-BCP-COVER: % procesos críticos con planes actualizados.
 - M-RES-TEST-COVER: % pruebas de continuidad realizadas vs planificadas.
 - M-RES-RTO-MEET: % pruebas que cumplen RTO/RPO.

6.7 Proveedores y terceros (G-SUP-*)

- Goal G-SUP-1: “Mantener un nivel de riesgo aceptable asociado a proveedores y terceros críticos.”
- Métricas:
 - M-SUP-CRIT-EVAL: % proveedores críticos evaluados y aprobados.
 - M-SUP-SEC-CLAUSE: % proveedores con cláusulas de seguridad adecuadas.
 - M-SUP-INC: N° incidentes asociados a terceros.

6.8 Regulación y entorno externo (G-REG-*)

- Goal G-REG-1: “Demostrar diligencia razonable y cumplimiento de NIS2, GDPR y requisitos nacionales mediante un set coherente de indicadores.”
- Métricas:
 - M-REG-NIS2-ALIGN: Índice de alineamiento percibido con NIS2.
 - M-REG-BREACH: N° brechas de datos y tiempos de notificación.

6.9 Automatización, calidad de datos y gobierno (G-GOV-*)

- Goal G-GOV-1: “Asegurar que la medición se apoya en datos de calidad y procesos automatizados donde tenga sentido.”
- Métricas:
 - M-GOV-AUTO: % de datos de indicadores obtenidos automáticamente.
 - M-GOV-DATAQUAL: Índice de calidad percibida de datos.

7. Integración operativa GQM + PRAGMATIC

El ciclo recomendado para cada métrica es:

10. Definir el objetivo (Goal).
11. Derivar preguntas y métricas (GQM).
12. Calificar la métrica con PRAGMATIC (1–5 en cada criterio). [web:44][web:52]
13. Descartar o reformular métricas con baja puntuación global o con defectos graves (por ejemplo, no accionables o no genuinas).
14. Incorporarlas al catálogo ISO 27001 con trazabilidad hacia objetivos nacionales y regulatorios.

Este marco se utiliza en los documentos complementarios (matriz PRAGMATIC, plantilla Excel, etc.) para asegurar coherencia y evitar el síndrome del indicador “bonito pero inútil”.